Password Cracking

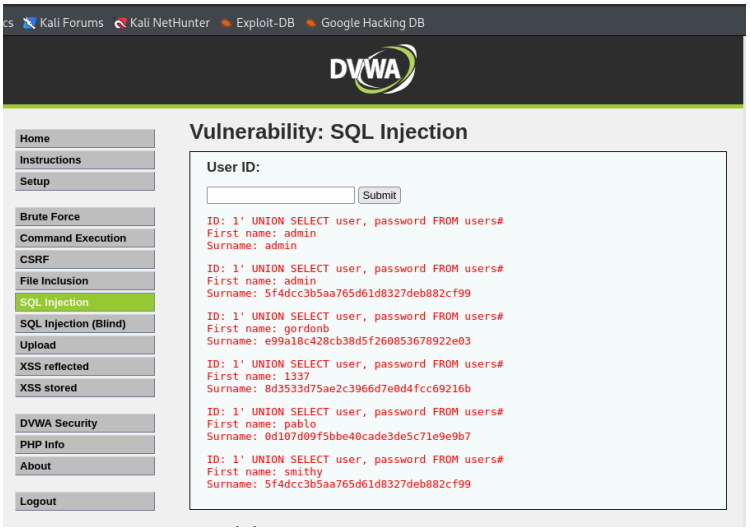
Luca Calzia - 12/11/2026

1. Obiettivo

L'obiettivo dell'esercizio è recuperare, tramite SQL injection, gli hash delle password presenti nel database di DVWA e utilizzare strumenti di cracking, come John the Ripper, per individuare le corrispondenti password in chiaro. L'attività prevede l'estrazione degli hash, la verifica dell'algoritmo MD5 e l'esecuzione di tentativi di cracking offline, con l'obiettivo di recuperare tutte le password estratte. L'esercitazione si svolge in un ambiente controllato composto da macchine virtuali e permette di comprendere i rischi delle SQL injection e dell'utilizzo di MD5 per memorizzare le password.

1. Troviamo le password

Iniziamo facendo SQL injection sulla nostra DVWA per trovare i dati sensibili degli utenti.



Troviamo quindi le password:

- **5f4dcc3b5aa765d61d8327deb882cf99**
- **e99a18c428cb38d5f260853678922e03**
- **8d3533d75ae2c3966d7e0d4fcc69216b**
- **0d107d09f5bbe40cade3de5c71e9e9b7**
- **5f4dcc3b5aa765d61d8327deb882cf99**

A questo punto prepariamo un file.txt con le righe nel formato utente:password

admin:5f4dcc3b5aa765d61d8327deb882cf99

gordonb:e99a18c428cb38d5f260853678922e03

1337:8d3533d75ae2c3966d7e0d4fcc69216b

pablo:0d107d09f5bbe40cade3de5c71e9e9b7

smithy:5f4dcc3b5aa765d61d8327deb882cf99

2. Sessione di cracking

Verifichiamo la disponibilità di John the Ripper e del dizionario RockYou, contenente le password candidate da provare.

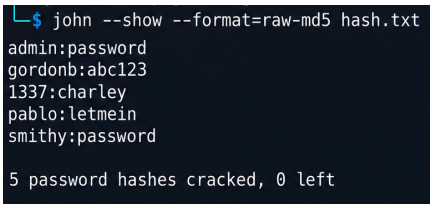
Avviamo John specificando il formato Raw-MD5. Il programma calcola gli hash delle password candidate e li confronta con quelli estratti, senza inviare tentativi di accesso a DVWA.

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt
/home/kali/Desktop/photo(1)(1)/hash.txt
```

--format=raw-md5 Specifica il tipo di hash.

--wordlist=...Indica il dizionario delle password candidate.

hash.txtIndica il file da analizzare.



L'obiettivo è completato quando tutte le righe degli utenti estratti hanno una password recuperata. Il dizionario non garantisce il recupero di qualsiasi password: se ne rimangono, il prossimo tentativo va scelto in base ai risultati effettivi.